

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 3 Lab Assignment: Risk Management Fundamentals

Lab Objectives:

This lab assignment is designed to help you:

- Understand the fundamental concepts of risk management in cybersecurity
- Apply risk identification, assessment, and mitigation methodologies
- Develop skills in creating risk matrices and prioritizing risks
- Gain practical experience in developing risk treatment plans

Instructions:

Complete all parts of this lab assignment. Submit your completed document to your instructor by the due date. All answers should be typed directly into this document.

Part 1: Risk Management Concepts (20 points)

1. Define the following terms in your own words and explain their relationship to each other: risk, threat, vulnerability, impact, and likelihood. (10 points)

- Risk is the possibility that something unwanted could happen because a threat takes advantage of a weakness in a system. In cybersecurity, risk is about understanding what could go wrong and how serious the consequences would be.
- A threat is anything that has the potential to cause harm. It could be a malware, an insider, a natural disaster, or even human error.
- A vulnerability is a weakness that can be exploited by a threat. Examples include outdated software, weak passwords, or misconfigured cloud storage.
- Impact refers to the consequences if the risk becomes a reality. This could include financial loss, regulatory penalties, service downtime, or damage to an organization's reputation.

- Likelihood is the chance that a threat will successfully exploit a vulnerability. Some risks happen frequently, while others are rare.

A threat looks for a vulnerability to exploit. If it succeeds, it creates a risk. The seriousness of that risk depends on the likelihood of it happening and the impact it would have on the organization.

2. Compare and contrast qualitative and quantitative risk assessment methodologies. What are the advantages and disadvantages of each approach? When would you recommend using one over the other? (10 points)

Qualitative Risk Assessment	Quantitative Risk Assessment
Uses descriptive ratings like Low, Medium, or High.	Uses numerical values and financial estimates.
Easier and faster to perform.	Requires historical data and accurate financial information.
Relies more on expert judgement.	Relies more on calculations and measurable data.

Advantages of Qualitative Assessment

- Easy to perform
- Requires fewer resources
- Suitable during the early stages of a project
- Encourages discussions among stakeholders

Disadvantages

- Can be subjective
- Different people may rate the same risk differently

Advantages of Quantitative Assessment

- Produces measurable results
- Supports budgeting and investment decisions
- Helps justify security spending

Disadvantages

- Time consuming
- Requires reliable historical and financial data
- More difficult for smaller organizations

I would use a qualitative assessment during the planning phase of a project because it quickly highlights the biggest concerns. Once more information is available, I would use quantitative analysis to estimate the financial impact and help management prioritize investments.

Part 2: Risk Identification Exercise (25 points)

For this exercise, consider a medium-sized financial services company that is planning to migrate its customer relationship management (CRM) system from an on-premises solution to a cloud-based service. The CRM system contains sensitive customer financial information and personally identifiable information (PII).

Identify at least 10 potential risks associated with this migration. For each risk, provide:

1. A clear risk statement
2. The risk category (e.g., technical, operational, compliance, reputational)
3. The potential threat source or actor
4. The vulnerability being exploited

Risk Statement	Risk Category	Threat Source/Actor	Vulnerability
Customer data could be exposed during migration.	Technical	Cybercriminal	Insecure data transfer
Sensitive financial records could be accessed by unauthorized users due to incorrect cloud permissions.	Technical	Internal users or attackers	Misconfigured access controls
The company may fail to meet data protection regulations after migration.	Compliance	Regulatory bodies	Poor compliance planning
Customer information could be stolen if employee accounts are compromised.	Security	Phishing attackers	Weak authentication
Cloud service downtime could interrupt customer services.	Operational	Cloud provider failure	Dependence on a single provider
Data may be accidentally deleted during migration.	Operational	Human error	Poor migration procedures
Backup systems may fail to restore customer information after migration.	Technical	System failure	Inadequate backup testing
APIs connecting the CRM to other business systems may introduce security weaknesses.	Technical	External attackers	Insecure APIs
Employees may accidentally share sensitive information	Operational	Employees	Lack of security awareness training

because they are unfamiliar with the new cloud platform.			
Negative publicity following a data breach could reduce customer trust.	Reputational	Public and media	Poor incident response and inadequate security controls

Part 3: Risk Assessment Matrix (25 points)

From the risks you identified in Part 2, select the five most significant risks and complete the following risk assessment matrix. For each risk:

1. Assign a likelihood rating (1-5, where 1 is rare and 5 is almost certain)
2. Assign an impact rating (1-5, where 1 is negligible and 5 is severe)
3. Calculate the risk score (likelihood × impact)
4. Determine the risk level based on the score:
 - Low: 1-4
 - Medium: 5-9
 - High: 10-15
 - Critical: 16-25

Risk	Likelihood (1-5)	Impact (1-5)	Risk Score	Risk Level
Customer financial data exposed during migration	4	5	20	Critical
Incorrect cloud permissions allowing unauthorized access	4	5	20	Critical
Regulatory non-compliance	3	5	15	High
Employee account compromise through phishing	4	4	16	Critical
Cloud service outage affecting operations	3	4	12	High

Part 4: Risk Mitigation Strategies (30 points)

For the three highest-rated risks from your assessment in Part 3, develop detailed risk mitigation strategies. For each risk:

1. Describe the risk mitigation approach (avoid, transfer, mitigate, or accept)
2. Provide specific controls or actions to implement
3. Identify the responsible stakeholders
4. Establish metrics to measure the effectiveness of the mitigation
5. Estimate the residual risk after mitigation (low, medium, or high)

Risk 1:

Risk Statement	Customer financial information could be exposed while migrating data to the cloud.
Mitigation Approach	Mitigate
Specific Controls/Actions	• Encrypt data before and during migration • Use secure communication protocols such as TLS • Validate migrated data before making it available • Perform migration in phases rather than all at once • Monitor migration logs for unusual activity
Responsible Stakeholders	• Security Team • Cloud Engineers • Database Administrators • Project Manager
Effectiveness Metrics	• Zero unauthorized access incidents • Successful encryption verification • Migration completed without data loss • Security audit passed
Residual Risk	Low

Risk 2:

Risk Statement	Unauthorized users could gain access to sensitive customer information because of incorrect cloud permissions
Mitigation Approach	Mitigate
Specific Controls/Actions	• Implement Role-Based Access Control • Enforce Multi-Factor Authentication • Apply the Principle of Least Privilege • Conduct regular access reviews • Enable continuous monitoring and logging.
Responsible Stakeholders	• IAM Administrators • Security Team • Cloud Administrators
Effectiveness Metrics	• Number of unauthorized access attempts. • Percentage of accounts protected by MFA. • Results of quarterly access reviews.
Residual Risk	Low

Risk 3:

Risk Statement	Employees may fall victim to phishing attacks, leading to compromised CRM accounts
Mitigation Approach	Mitigate
Specific Controls/Actions	• Conduct regular phishing awareness training • Deploy email filtering solutions • Require MFA for all CRM users • Run periodic phishing simulation exercises • Establish a clear incident reporting process
Responsible Stakeholders	• Security Awareness Team • IT Department • Human Resources
Effectiveness Metrics	• Reduction in phishing click rates • Percentage of staff completing awareness training • Number of reported phishing emails • Reduction in compromised accounts
Residual Risk	Medium

Submission Guidelines:

1. Save this document with the filename format:

GRC101_Week3_Lab_FirstName_LastName.docx

2. Submit your completed lab assignment through the course learning management system.

3. Due date: [Instructor to specify]

Grading Rubric:

- Part 1: Risk Management Concepts - 20 points
- Part 2: Risk Identification Exercise - 25 points
- Part 3: Risk Assessment Matrix - 25 points
- Part 4: Risk Mitigation Strategies - 30 points

Total: 100 points